Footprinting, Reconnaissance and Social-Engineering-Awareness Workflows in an Authorized Assessment

Course: ITA14 Ethical Hacking · **Assignment 2 (CO2)** · **Name / Reg. No.:** KEERTHIKA 192321118

Evidence notes (read first): All targets are **lab-owned or reserved example names** (`examplecorp.example`, `192.168.56.0/24`, lab BIND server). No real organisation, individual or live system is touched. **Q1–Q3 observation columns are sample lab results**: run the given commands in your own lab and paste your actual output over them (raw output files are required by the submission rules). **Q4–Q6 numbers are measured** by the accompanying script `sim.py` (offline, fixed random seeds, reproducible). Execution time is supporting evidence only.

Q1 – Evaluate and Engineer a Footprinting Strategy (8)

1.1 Understand: scope, authorization and technique classes

Authorization record (pre-condition): Engagement `ENG-A2-001`, client *examplecorp* (lab), authorised domain `examplecorp.example` (+ lab zones below), owner-signed scope file, window: lab – any time. Anything not in the scope file is out of scope.

Classification rule: *Passive* = no packet from the tester reaches infrastructure owned by the target (the tester only talks to registries, search engines, archives, public resolvers). *Active* = the tester sends traffic to target-owned servers (authoritative DNS, web, mail).

Technique	Tool/operator	Class	Reason
WHOIS lookup	`whois examplecorp.example`	Passive	Talks to the registry/registrar
Search-engine operators	`site:`, `filetype:`, `intitle:`, `inurl:`	Passive	Talks only to the search engine
Archived pages	Web archive snapshots	Passive	Reads third-party copies
Certificate-transparency log search	CT log web search	Passive	Public logs
DNS via a public/recursive resolver	`dig @9.9.9.9 …`	Passive-indirect	Target's name server may see the resolver, not the tester
DNS directly at the target's authoritative server	`dig @ns1.examplecorp.example …`, `nslookup`	**Active**	Packets reach target infrastructure

Zone transfer (AXFR)	`dig axfr …`	**Active (intrusive)**	Requests the entire zone; needs explicit written permission
Banner/HTTP probing	`curl -I`	**Active**	Contacts target services

1.2 Strategy (ordered steps)

1. **S0 Scope load:** read the scope file (allow-list of domains/IP ranges); load deny-list (third parties).
2. **S1 Passive sweep:** WHOIS; search operators; archive; CT logs. Output: candidate hostnames, contacts (flagged PII), technologies.
3. **S2 DNS via resolver:** A, AAAA, MX, NS, TXT, CNAME for each in-scope candidate.
4. **S3 Active confirmation (only in-scope, in window):** query authoritative servers directly; AXFR only if the scope file states *AXFR permitted*.
5. **S4 Correlate and compare sources**, mark contradictions.
6. **S5 Validate (Q4)** before anything is reported as an attack-surface item.

Commands:

```
whois examplecorp.example > raw/whois_examplecorp.txt
dig +noall +answer examplecorp.example A MX NS TXT > raw/dig_basic.txt
dig +noall +answer @9.9.9.9 www.examplecorp.example A   # resolver view
dig +noall +answer @192.168.56.53 www.examplecorp.example A   # authoritative (lab)
nslookup -type=MX examplecorp.example 192.168.56.53
# search operators (manual, logged):
#   site:examplecorp.example filetype:pdf
#   site:examplecorp.example intitle:"index of"
#   site:examplecorp.example inurl:admin
```

1.3 Treating findings by status (not all results are equal)

Every item is tagged with three attributes before use:

Attribute	Values	Handling
Scope	IN / OUT / UNKNOWN	OUT is dropped and logged; UNKNOWN is held until the owner confirms
Personal data	PII / NON-PII	PII (registrant names, e-mails, phone numbers) is redacted in the report and stored encrypted; not used for attack-surface counts
Verification	V0 unverified, V1 single source, V2 corroborated by ≥ 2 independent sources	Only IN + NON-PII + V2 go to the attack-surface summary; V0/V1 are listed as "leads"

1.4 Four contrasting authorized targets (lab zones on BIND at 192.168.56.53)

Target	Design	Prediction before	Sample observation (lab)	Match?

		collection		
T1 well-protected `secure.examplecorp.example`	WHOIS privacy on; AXFR denied; no wildcard; only `www`, `mail`; SPF + DMARC; generic admin contact	WHOIS: redacted. DNS: 2 hosts. TXT: SPF/DMARC only. Search: no leaks	WHOIS redacted; 2 A records, 1 MX; AXFR `REFUSED`; no indexed documents	Yes
T2 leaky `leaky.examplecorp.example`	WHOIS shows admin name/e-mail; TXT holds verification tokens; public PDF with internal hostnames; archived page shows old `/admin`	WHOIS PII; TXT reveals SaaS vendors; search finds the PDF	WHOIS shows personal e-mail (PII); TXT shows 2 vendor tokens; PDF metadata lists `fileserver01` and author name; archive shows `/admin`	Yes (author name was not predicted)
T3 misconfigured DNS `miscfg.examplecorp.example`	AXFR allowed from any host; dangling CNAME `old-shop` → removed provider; internal IP in public A record	AXFR succeeds; ≥ 15 records; one dangling CNAME	AXFR returned 24 records; dangling CNAME found; 2 private (10.x) addresses visible	Partly (24 records > 15; private IPs not predicted)
T4 minimal `min.examplecorp.example`	One A record; no MX; no TXT; no indexed pages; WHOIS privacy	Almost nothing found	1 A record; `NXDOMAIN` for `mail`; search returned 0 results	Yes

Contradictions between sources observed: (1) WHOIS lists 2 name servers but a direct NS query returns 3 (a stale registrar glue record) → DNS (authoritative) trusted over WHOIS. (2) Archive shows `shop.leaky…` live a year ago but DNS returns `NXDOMAIN` today → historical, not current. (3) Resolver returns an old A record for `www.leaky…` (TTL cache) while the authoritative server returns a new IP → authoritative answer wins; re-query after TTL.

1.5 Source reliability

Source	Reliability (0–1)	Typical weakness	Rule of use
Authoritative DNS (active)	0.95	Split-horizon: external view only	Primary for current records
Recursive-resolver DNS	0.80	Cache/TTL staleness	Confirm with authoritative
WHOIS	0.60	Privacy redaction, stale contacts, registrar differences	Ownership/dates only; contacts are PII
Search engines	0.60	Incomplete, ranking-dependent, stale snippets	Leads only (V1) until confirmed

Web archive	0.40	Old, partial, may show removed assets	Historical context only
Public documents	0.50	Metadata may be outdated or generic	Leads; confirm by DNS/active check

Misleading/outdated sources identified: WHOIS name servers, web-archive snapshots, resolver caches.

1.6 Changed condition: 50 subdomains + third-party services

Evaluation of the original strategy: per-host manual passive and active steps cost roughly 9 active queries per host (Q6 model) → 450 queries for 50 hosts; third-party services (CDN, SaaS, e-mail provider) appear in CNAME/MX/TXT records and are *not* owned by the client, so touching them is out of scope.

Modifications: (a) Subdomain discovery from CT logs + search first (bulk passive) rather than guessing; (b) batch DNS queries from a file with caching of shared NS/MX answers; (c) a *third-party register*: any host whose CNAME/NS points outside the allow-list is recorded as **"third-party – identified only, not probed"** unless the provider's written consent exists; (d) automatic V0–V2 tagging and the Q4 validator; (e) rate limiting for stealth.

Defence: the original *method* (passive → DNS → active, with scope/reliability tagging) stays suitable because its ordering and tagging are independent of host count; only the *execution* (manual, per host) is not. With the modifications the same method scales (see Q6: 31 passive queries for 50 hosts versus 450 active).

Q2 – Reliable DNS Footprinting Workflow (7)

2.1 Workflow

```
for each in-scope domain D (from scope file):
  1. NS   : dig +short D NS            -> list of authoritative servers (record
delegation)
  2. A/AAAA/MX/TXT/CNAME via resolver and via each authoritative NS (compare)
  3. If any record points outside scope -> tag THIRD-PARTY, do not probe
  4. If scope says "AXFR permitted" AND NS is in scope: dig @NS D axfr
     else: log "AXFR not attempted (not authorized)"
  5. Compare resolver vs authoritative answers; note TTL and serial (SOA)
  6. Output table: record, value, TTL, source (resolver/auth/AXFR), tag (IN/OUT,
V0–V2)
```

Equivalent `nslookup` forms: `nslookup -type=NS D`, `nslookup -type=MX D <ns>`, `nslookup -type=TXT D <ns>`, `nslookup -query=AXFR` is not used (use `dig axfr` for clarity and logging).

2.2 How DNS behaviours change what the tester sees

Behaviour	Effect on an external tester	Workflow response
Split-horizon (internal vs	Only the external view is visible; internal hosts cannot be seen	Report that absence is not proof of non-existence; never infer internal topology from

external view)	from outside	external silence
Delegation	Subzone answered by another NS (maybe third party)	Follow NS chain; if the delegated NS is outside scope → stop, tag THIRD-PARTY
Caching/TTL	Recursive resolver can serve old answers until TTL expires	Compare with the authoritative answer; record TTL; re-query after expiry
Wildcards	`*.D` makes any name resolve → false "hosts"	Test a random name (`zz9x.D`); if it resolves, flag wildcard and discount brute-force results

2.3 Six (plus one) contrasting cases

Case	Zone setup (lab)	Prediction	Sample observation	Match?
C1 secure	AXFR denied, TSIG only for secondaries	A, MX, NS, TXT visible; AXFR `REFUSED`	As predicted; 6 records visible	Yes
C2 zone transfer allowed	`allow-transfer { any; }`	Whole zone leaks	24 records incl. `dev`, `vpn`, `backup`, `db01`	Yes
C3 stale records	Old A for `www` after migration; one dangling CNAME	Resolver may show old IP; CNAME target NXDOMAIN	Resolver (TTL 3600) returned old IP for 40 min; CNAME dangling (takeover risk)	Yes
C4 split-horizon	Internal view has `intranet`, external does not	External query for `intranet` returns NXDOMAIN	NXDOMAIN externally	Yes
C5 delegated to third party	`shop.D` NS → provider	Probing stops at delegation	NS returned provider names → tagged THIRD-PARTY, not probed	Yes
C6 caching difference	Change record, TTL 300	Resolver and authoritative differ for ≤ 5 min	Differ for 4 min	Yes
C7 TSIG-protected transfer	AXFR requires TSIG key	AXFR without key fails	`Transfer failed` / `NOTAUTH`	Yes

2.4 Does a misconfigured zone transfer matter?

Knowledge gained: without AXFR the tester must guess or discover names (CT logs, search, wordlists), typically finding the public-facing hosts (about 6 of 24 in the lab zone). AXFR gives *complete* names,

record types, internal addresses, mail routing, verification TXT records and *naming conventions* in one query, including non-public hosts (`db01`, `backup`) that no passive source reveals.

Aspect	Without AXFR	With open AXFR
Queries to learn the zone	100+ guesses/discoveries	1
Hosts known	6 of 24	24 of 24
Internal/sensitive names	Not visible	Visible
Detectability	Many queries (noisy)	One query (quiet)
Risk level	Low–Medium	**High** (information disclosure that guides targeted attacks)

Conclusion: yes, it meaningfully changes attacker knowledge (completeness and stealth), although it does not itself give access; it reduces effort and focus for later attacks.

2.5 Countermeasure and redesign

BIND configuration in the lab (illustrative):

```
key "xfer-key" { algorithm hmac-sha256; secret "<base64-lab-secret>"; };
zone "examplecorp.example" {
  type master; file "db.examplecorp";
  allow-transfer { key "xfer-key"; };   // or: { 192.168.56.54; } for the one
secondary
};
```

Redesigned analysis: the workflow now expects AXFR `REFUSED`/`NOTAUTH` for unauthorised clients. Exposure re-measured on C2 after the change: records leaked by AXFR 24 → **0**; hosts discoverable by an outsider 24 → 6 (public names only); queries needed by an outsider to learn the same 6 hosts: about 100+ (noisier, easier to detect). Remaining risk: public records, dangling CNAME and TXT leaks (fix separately: delete stale records, remove unneeded verification tokens).

Q3 – Competitive-Intelligence Awareness Utility (7)

3.1 Workflow architecture (modular)

```
[Source modules] -> [Extractor] -> [Item store] -> [Technique mapper] -> [Risk
scorer] -> [Report + countermeasures]
  jobs | annual | press | profiles     (item = what, where from, date, confidence)
```

Each source module is a plug-in with the same interface (`query()`, `extract_items()`), so new sources can be added without changing the other stages.

3.2 Source operators and documentation

Source	Search operators (logged with date and result count)	Items recorded

Job advertisements	`site:examplecorp.example intitle:careers`, `"examplecorp" "experience with" jobs`	Technology stack, internal tool names, hiring manager, office locations
Annual reports	`site:examplecorp.example filetype:pdf "annual report"`	Org structure, subsidiaries, vendors, locations
Press releases	`site:examplecorp.example intitle:"press release" OR intitle:news`	Partners, events, contact formats
Public profiles	`"examplecorp" intitle:profile`, role/name searches in public directories	Names, roles, reporting lines, new joiners

Every item stores: source, URL (synthetic here), operator used, retrieval date, text snippet, confidence.

3.3 Item → technique → indicator mapping

Item	Enables	Why	Indicator the target should notice
Staff name + role + manager	Pretexting, vishing	Caller can impersonate a manager	Unexpected "urgent" request invoking a named manager; request bypassing normal channel
E-mail address format (first.last@)	Phishing	Addresses can be guessed	Mail from look-alike domain or unusual reply-to
Internal tool names (e.g. "Aurora HR portal")	Phishing, pretexting	Fake login pages and convincing scripts	Login link not on the known URL; unexpected password prompt
Technology stack in job ad	Phishing, vishing ("IT support" pretext)	Credible technical story	"IT" asking for credentials or remote access
New joiners and onboarding dates	Pretexting	New staff do not know procedures	Request for credentials within first weeks without ticket
Office address, shift times	Tailgating	Predictable entry/exit times	Unknown person without badge following staff
Vendor/partner names	Phishing (invoice fraud), vishing	Fake supplier messages	Changed bank details, urgency
Help-desk staff names	Vishing	Impersonating or targeting the help desk	Caller asks help desk to reset an account without verification

3.4 Test organizations (synthetic public information)

Org	Public-information profile	Prediction
RichCorp	Detailed job ads, org chart in report, press with contacts, active staff profiles	Very high exposure (≈ 90)
SparseCorp	One generic job ad, brief report, no profiles	Low (< 10)
MisleadCorp	Outdated tools, a fake partnership, profile of a departed employee, old org chart	Medium raw score but low real risk (< 10 after confidence weighting)

3.5 Scoring rubric

`item risk = Specificity (1–3) × Actionability (1–3)`; `weighted risk = item risk × confidence`. Human-risk level: 0–20 Low, 21–50 Medium, 51+ High.

3.6 Prediction versus observation

Org	Source	Items (S×A)	Source score
RichCorp	Job ads	tech stack 3×2=6; internal tool 3×3=9; hiring manager 2×3=6; office/badge 2×2=4	**25**
RichCorp	Annual report	exec names 2×2=4; subsidiaries 1×2=2; vendors 2×2=4	10
RichCorp	Press releases	new partner 2×3=6; event dates 1×2=2; e-mail format 3×3=9	17
RichCorp	Public profiles	role/name 2×3=6; reporting lines 3×3=9; new joiners 3×3=9; help-desk names 3×3=9	**33**
RichCorp total			**85** (High)
SparseCorp	Job ad 2×1=2; press 1×1=1; report 1×2=2; profiles 0		**5** (Low)
MisleadCorp	Old tool 6 (conf. 0.3); fake partner 6 (0.2); departed employee 6 (0.3); old org chart 4 (0.4)	raw 22	weighted **6.4** (Low)

Prediction check: Rich predicted ≈ 90, observed 85 (High, correct). Sparse predicted < 10, observed 5 (correct). Misleading predicted raw medium and weighted < 10: observed raw 22, weighted 6.4

(correct). Prediction error: the most dangerous source was predicted to be job ads, but **public profiles (33)** scored highest because they give names, reporting lines and new joiners together.

3.7 Does the information really increase risk? Most dangerous source?

Yes for RichCorp: 85 vs 5 for SparseCorp – about 17× more usable material for pretexts. The *combination* matters more than any single item (name + manager + internal tool = a complete vishing script). **Most dangerous source: public profiles (39% of RichCorp score), then job ads (29%).** Misleading information lowers real risk but wastes assessor time and can mislead defenders (verify before reporting).

3.8 Extension without restructuring

Two new sources (new modules, same interface): (S5) conference/slide decks: network diagram 3×3=9, vendor tooling 2×2=4 → +13; (S6) public code-repository metadata (synthetic): committer e-mail 3×3=9, internal hostnames 3×2=6 → +15. RichCorp total 85 → **113**; none of the existing five stages changed.

Two new countermeasures (apply to the mapper output): (CM-A) role-based contact addresses (e.g. `careers@`, `press@`) in ads and releases, removing hiring-manager name (6) and e-mail format (9) → −15; (CM-B) profile guidance + verification call-back procedure + onboarding warning, lowering Actionability by one point for reporting lines, new joiners and help-desk names (9→6 each) → −9.

RichCorp	Score	Level
Original (4 sources)	85	High
After adding S5, S6	113	High
After CM-A + CM-B (on 113)	89	High
After CM-A + CM-B (on original 85)	61	High (down 28%)

Evaluation: countermeasures cut the score by about 24 points but the organisation remains High: awareness measures reduce *actionability*, but only reducing *what is published* lowers the base. Recommended countermeasures summary: generic contact roles; limit staff detail in ads and reports; verify-by-call-back policy; new-joiner briefing; badge and tailgating policy; periodic re-run of this workflow.